MAJO BRIDGE TECHNOLOGIES AND EVENTS PLC

MaJo e-School Bridge (MayaBela) · INSA asset registration attachment

System and Architecture Design Document (SDD)

System and Architecture Design Document

Product: MaJo e-School Bridge (MayaBela)

Structure, interactions, attack surfaces, data flows, and trust boundaries

Document number	MB-SDD-001
Version	1.0 · 10 November 2026 · East Africa Time (Africa/Nairobi)
INSA portal field	System & Architecture Design Document (SDD) — describes system structure and interactions; used to identify attack surfaces, data flows, and trust boundaries.
Companion	MB-SRS-001 (requirements, roles, controls)
Classification	CONFIDENTIAL (CMCSRS Annex B) — architecture of a system that stores children's records. No live secrets in this file.

This SDD describes the **as-designed** hosted architecture. Disk encryption keys on the current hosted database remain with the supplier (CMCSRS §6.29.f residual). A dedicated/on-prem instance for a school that cannot share this tenancy is the same application with a separate database URL — not a second product.

1. Purpose

This document is the architecture baseline for INSA asset registration. It shows how components interact, where data crosses a trust boundary, and which surfaces an attacker (or a mis-scoped JWT) can reach. Security requirements are in MB-SRS-001; this file is structure and flow.

2. System context

```
  [ Teacher / Admin / Finance / Registrar / HR / Parent / Student / Driver ]
           |  HTTPS (browser or mobile)
           v
TB-1  [ Cloudflare Pages : mayabela.pages.dev ]     static Flutter web
           |  HTTPS
           v
TB-2  [ Hosted backend (Supabase project) ]
           |-- Auth (JWT mint / refresh)
           |-- PostgREST + Postgres  (app_documents, RLS)
           |-- Storage               (school-branding PUBLIC logos;
           |                          school-files PRIVATE under schools/<id>/)
           |-- Edge Functions        (login, registry, platform PIN, AI, mail)
           |
           +-- optional: generative model (Maya Assistant, counts-only)
           +-- optional: mail / FCM push providers
           +-- MaJo laptops / CI (GitHub Actions) — DSAPs; service-role never in the app
```

Mobile builds of the same Flutter codebase talk to the same TB-2 endpoints. They do not embed a private CA. TLS is terminated by the hosted vendor.

3. Logical structure

3.1 Presentation

One Flutter application (web on Cloudflare Pages; mobile stores). The anon / publishable API key is compiled into the client (PUBLIC). It is not an encryption key. Authorisation is the JWT plus RLS. The service-role key must never appear in Dart, HTML, or mobile binaries.

3.2 Application / API

- **PostgREST** on `public.app_documents` keyed by `(collection, school_id, doc_id)`. RLS and a write-guard trigger enforce school and role. Driver SELECT is further restricted to assigned-bus students.
- **Edge Functions** (25) when the client cannot use RLS alone (password verify, PIN, service-role writes, public intake). Each function has a declared auth mode in `edge_auth_inventory.ts`; CI fails if a folder is added without one.

3.3 Data

Store	Content	Annex B	Trust
Postgres `app_documents`	SIS, marks, fees, HR, transport, audit	CONFIDENTIAL	Inside TB-2; RLS is the tenant wall
Auth users / JWT	schoolId + role in `app_metadata`	CONFIDENTIAL	DB helpers ignore user-editable metadata
`school-files`	Photos, documents under `schools/<id>/`	CONFIDENTIAL	Authenticated; prefix must match JWT school
`school-branding`	Login logos / stamps	PUBLIC	Anon SELECT; no student files
Edge secrets	Service-role, mail, optional AI key, push secret	CONFIDENTIAL	TB-2 only; DSAPs

4. Trust boundaries

ID	Boundary	Untrusted side	Trusted side	What must hold
TB-0	Internet / user device	Browser, phone, stolen laptop	—	Treat as hostile. XSS, lost phone, shared teacher PC.
TB-1	Pages CDN	Anyone who can GET mayabela.pages.dev	Static assets + CSP/HSTS headers	No CONFIDENTIAL data in the static build except the public anon key. Student rows are not in the JS bundle.
TB-2	Hosted API (HTTPS to *.supabase.co)	Any client with the anon key	Auth, PostgREST, Storage, Edge	No JWT → no `app_documents`. With JWT → only that `school_id`. Service-role only inside Edge after an application gate.
TB-3	School tenant	JWT of School A	Rows of School A	School A must not read School B (CAAT two-school 7/7 in source).
TB-4	Role / need-to-know	Teacher / driver / parent JWT	Class, bus, or linked child	Driver: own bus only. Teacher: assigned class; no payroll. Parent: linked child.
TB-5	Public vs authenticated storage	Unauthenticated GET	Logos only	Login page has no JWT, so branding is public by design. Student files must not live in that bucket.
TB-6	Platform owner	School JWT	Owner PIN + rate-limit	Provisioning must not use a teacher JWT. PIN is PBKDF2-SHA256.
TB-7	Optional AI	Prompt text	Gemini (if key set)	Counts-only context; refuse health/safeguarding/IDs. Unset key → 412; ERP still works.
TB-8	Supplier hypervisor	MaJo as cloud customer	Host disks / backups	Residual: supplier holds at-rest keys (§6.29.f). Not a Flutter control.

5. Data flows

5.1 School login (password)

```
Device --HTTPS--> school-login (public, rate-limited)
                    |  verify bcrypt secret for schoolId+username+role
                    v
                Auth mints JWT (app_metadata.schoolId, role)
                    |
Device <-- JWT -----'
Device --JWT--> PostgREST / Storage / other Edge  (TB-2, TB-3, TB-4)
```

Privileged MFA (Admin, Finance): after password success, Settings requires TOTP enrolment. Teachers are not blocked from class if MFA is unset.

5.2 Ordinary classroom write (attendance / homework / marks)

```
Teacher JWT --HTTPS--> PostgREST INSERT/UPDATE app_documents
                         |  RLS: school_id = jwt_school_id()
                         |  write-guard: collection + assigned class
                         v
                       Row stored  |  grade_audit_log append-only (marks)
```

5.3 Privileged registry write (admissions / student row via Edge)

```
Staff JWT --HTTPS--> school-upsert-registry
                       |  verify JWT
                       |  guardRegistryRecord (registrar for admissions)
                       |  service-role upsert (RLS bypassed; gate replaces it)
                       v
                     app_documents
```

5.4 Driver location

```
Driver JWT --> bus_live_positions / transport_scans
                 |  RLS + driver trigger: transportId == busId
                 v
               Only that bus; other-bus / walker students not readable
```

5.5 Public branding (no JWT)

```
Anyone --GET--> school-public-brand (rate-limited)  and/or
                storage public/school-branding/<school>/logo
                Returns name + logo URL. No emails, passwords, or student lists.
```

5.6 Maya Assistant (optional)

```
Staff JWT --> maya-assistant-chat
                |  counts-only snapshot (students=N, not names)
                |  if MAYA_AI_API_KEY set --> TB-7 model
                v
              Reply; safeguarding/health/password/ID prompts refused
```

6. Attack surfaces

Surfaces are listed so INSA can see what we expose, not as a pentest letter (that letter is still scheduled after staging apply).

ID	Surface	Who can reach it	Primary controls	Residual
AS-01	Static web (Pages)	Internet	HTTPS, HSTS, CSP, nosniff, DENY framing	XSS in third-party map/font origins allowed by CSP
AS-02	Anon API key in the client	Anyone who downloads the app	RLS; anon has no `app_documents` policy	Inherent to hosted anon model (Guideline mNC-07)
AS-03	school-login / password reset / register-parent / submit-application	Internet, no JWT	Rate-limit; no user-existence leak on reset; hashed secrets	Credential stuffing if school passwords are weak
AS-04	PostgREST with a stolen staff JWT	Anyone with that token until expiry	TB-3/TB-4 RLS; MFA on Admin/Finance	Teacher JWT theft on a shared PC — MFA not forced on teachers
AS-05	Storage public branding	Internet	Logos only by policy	Mis-upload of a student file into branding would be a data spill (IRP)
AS-06	Storage school-files	Authenticated JWT	Prefix `schools/<jwt school>/`	Object ACL bugs would be High; CAAT/storage probes in source
AS-07	Edge with service-role	After JWT/PIN/public gate	Inventory + registry policy + PIN PBKDF2	A missed gate is equivalent to RLS bypass — CI tracks inventory
AS-08	Platform owner PIN	Internet to those functions	Rate-limit; PBKDF2; no school JWT	PIN reuse / shoulder-surfing at the vendor desk
AS-09	send-push	Caller with x-push-secret	Secret; re-reads notification row (cannot forge body)	Secret in Edge config
AS-10	Maya Assistant	Staff JWT	Counts-only; refuse sensitive; optional key	User may still type a name into the prompt — instruction refuses to echo PII
AS-11	GitHub Actions / DSAPs	MaJo operators	Secrets in CI; production never the RLS test target	Human error; DSAP clearance files still national-scheme residual
AS-12	Supplier platform	Hosted CSP	DPA; no destructive tests on live project	Foreign host; keys not MaJo-held; locally licensed CSP not claimed

7. Edge Function auth modes (attack-surface catalogue)

Mode	Functions	Trust assumption
password-login	school-login	Secret verified; then JWT
user-jwt	refresh-claims, change-password, upsert-account, upsert-registry, delete-account, verify-student, maya-assistant-chat	Caller JWT; school isolation; extra desk checks where noted
platform-owner-pin	owner-pin, list/create/update/delete-school, upload-logo, upload-mark, mail-config	PIN, not a school JWT
public-rate-limited	password-reset pair, student-reset request, register-parent, invite-parent, submit-application, public-brand, client-crash-report	No JWT; rate-limit; no CONFIDENTIAL dump in the response

Mode	Functions	Trust assumption
push-secret	send-push	Shared Edge secret + stored notification row

8. Security design decisions (why this shape)

- **RLS in the database, not only the UI.** A modified client still hits TB-3.
- **Anon key public; service-role private.** Losing the anon key is not a breach if RLS holds.
- **Login logos public.** The login page cannot present a JWT; student files stay in a private bucket.
- **Teachers not forced onto MFA.** Privileged desks (Admin, Finance) are. Classroom availability is a stated requirement (MB-SRS-001).
- **One operator, many schools.** Encryption keys (when MaJo holds them on a future local/on-prem host) stay with MaJo, not each school. Isolation is JWT + RLS, not per-tenant disk keys handed to schools.

9. Related documents

MB-SRS-001 (requirements). CSMS-AST-001 (assets). CSMS-KEY-001 (crypto). CSMS-SUP-001 (cloud register). CSMS-DPIA-001 (AI). CSMS-IRP-001 (incidents). CAAT: `supabase/tests/local_pg`.

Prepared by (Engineering / CSO)

Majo Bridge Technologies and Events PLC · 10 November 2026, East Africa Time

For INSA asset registration

Attachment to field: System & Architecture Design Document (SDD)

Restricted. Not a gazetted INSA certificate and not a third-party pentest letter.